

Day 2 (Social Engineering)

1. SIEM (Security Information and Event Management)

Definition

SIEM is a centralized security platform that collects, stores, analyzes, and correlates logs from different devices to detect security threats in real time.

Main Functions

- Log Collection
- Log Storage
- Event Correlation
- Alert Generation
- Incident Investigation
- Compliance Reporting

Log Sources

- Windows/Linux Servers
- Databases (Oracle, MySQL, SQL Server)
- Firewalls
- IDS/IPS
- WAF
- VPN
- Routers & Switches
- PAM
- DAM
- EDR/XDR
- Antivirus
- Cloud Services
- Active Directory

How SIEM Receives Logs

Most devices **do not send logs using SNMP**.

Common methods:

Method	Purpose
Syslog	Linux, Firewalls, Routers
Windows Event Forwarding	Windows logs
Agent	SIEM agent installed on server
API	Cloud applications
Database Connector	Database logs
SNMP	Device health monitoring (CPU, RAM, Interface status), not security logs

Example

Firewall



Syslog



SIEM



Correlation Rule



Alert



SOC investigates

SNMP (Simple Network Management Protocol)

Purpose:

Monitor network device health.

It monitors:

- CPU Usage
- RAM Usage
- Interface Status
- Network Traffic
- Device Uptime

Not mainly used for:

- Malware Detection
- Threat Hunting
- Security Event Collection

Security Tools

PAM (Privileged Access Management)

Protects privileged accounts.

Examples

- Administrator
- Root
- Domain Admin

Functions

- Password Vault
- Session Recording
- Password Rotation
- Least Privilege

WAF (Web Application Firewall)

Protects web applications.

Stops

- SQL Injection
- Cross Site Scripting (XSS)

- File Inclusion
 - Command Injection
 - OWASP Top 10 attacks
-

DAM (Database Activity Monitoring)

Monitors database activities.

Detects

- Unauthorized queries
 - Data theft
 - Suspicious database access
 - Privileged abuse
-

EDR (Endpoint Detection and Response)

Protects endpoints.

Examples

- Laptop
- Desktop
- Server

Functions

- Malware Detection
 - Behavioral Analysis
 - Threat Hunting
 - Isolation
 - Response
-

XDR (Extended Detection and Response)

XDR combines security data from multiple sources.

Collects from

- Endpoint
- Firewall
- Email
- Cloud
- Identity
- Network

Examples

- Microsoft Defender XDR
- Symantec XDR
- Palo Alto Cortex XDR

Difference

EDR → Endpoint only

XDR → Endpoint + Network + Email + Cloud

UEBA (User and Entity Behavior Analytics)

Uses Machine Learning to detect abnormal behavior.

Example

Normal

User logs in every day at 8 AM.

Suspicious

Same user logs in at 3 AM from another country and downloads 500 GB.

SIEM alerts the SOC.

Threat Intelligence

Threat Intelligence is information about attackers and threats.

Includes

- Malicious IPs
- Malicious Domains
- Malware Hashes
- Indicators of Compromise (IOC)
- Tactics, Techniques, and Procedures (TTP)

Sources

- VirusTotal
- AlienVault OTX
- MISP
- Recorded Future

VirusTotal

Website used to analyze

- Files
- URLs
- IP addresses
- Domains
- Hashes

Purpose

Checks whether many antivirus engines detect them as malicious.

SOCIAL ENGINEERING

Definition

Manipulating people to reveal confidential information.

People are often the weakest security layer.

Human Factors

Attackers exploit:

Trust

"Hi, I'm from IT."

Authority

"The CEO needs this urgently."

Pressure

"Do it in 5 minutes."

Fear

"Your account will be disabled."

Curiosity

"Salary Increase.pdf"

Greed

"You won \$1000."

Types of Phishing

Email Phishing

Fake email.

Spear Phishing

Targets one person.

Whaling

Targets executives.

Example

CEO

CFO

Directors

Vishing

Voice phishing.

Phone calls.

Smishing

SMS phishing.

Clone Phishing

Copies a legitimate email.

Social Engineering Attacks

Keylogger

Records keyboard input.

Steals

- Passwords
 - Credit cards
 - Emails
-

Eavesdropping

Secretly listening to conversations.

Shoulder Surfing

Watching someone enter passwords.

Tailgating (Piggybacking)

Unauthorized person follows an authorized employee into a secure area.

Dumpster Diving

Searching trash for sensitive information.

Examples

- Passwords
- Printed reports
- Hard drives

Correct disposal: Shred paper, securely wipe or physically destroy storage media. Burning can be one destruction method where appropriate, but organizations typically follow approved media sanitization standards rather than relying only on fire.

Security Controls

Security Awareness

Train employees regularly.

MFA (Multi-Factor Authentication)

Three factors

Something you know

- Password

Something you have

- Phone
- Smart Card

Something you are

- Fingerprint
 - Face ID
-

Anti-Spam

Blocks

- Spam emails
 - Phishing emails
 - Malware attachments
-

Defense in Depth

Multiple layers of security.

Example

Firewall

↓

WAF

↓

IDS/IPS

↓

EDR

↓

SIEM

↓

SOC

If one layer fails, another provides protection.

Access Control

RBAC (Role-Based Access Control)

Users receive permissions based on their role.

Example hierarchy

Super Admin

↓

Admin

↓

Full Admin

↓

Read & Write

↓

Read Only

↓

Auditor (Read-only for auditing)

Principles:

- Least Privilege
 - Need-to-Know
 - Separation of Duties
-

VPN (Virtual Private Network)

Purpose

Creates an encrypted tunnel over the Internet.

Benefits

- Secure remote access
 - Data encryption
 - Protects public Wi-Fi usage
 - Hides traffic from local networks
-

Telnet

Port: **23**

Characteristics

- No encryption
 - Passwords sent in plain text
 - Insecure
 - Rarely used today
-

SSH (Secure Shell)

Port: **22**

Characteristics

- Encrypted communication
- Secure remote administration
- Supports password and key-based authentication

Exam Tip: Always prefer **SSH** over **Telnet**.

FortiClient

FortiClient is a security agent from Fortinet.

Features

- VPN client
 - Endpoint Protection
 - Zero Trust Network Access (ZTNA)
 - Vulnerability Scanning
 - Endpoint Compliance
 - Integration with Fortinet Security Fabric
-

EMS (Endpoint Management Server)

EMS centrally manages FortiClient endpoints.

Functions

- Deploy FortiClient
- Push security policies
- Manage VPN settings
- Software updates
- Endpoint inventory
- Compliance monitoring
- Remote endpoint control

Flow:

EMS



FortiClient



User Device

- Policy
- VPN Configuration
- Security Profile

